

Northbridge - SOC 2 Readiness and Evidence

Controls	22
Ready Controls	6
Partial Controls	15
Not Ready Controls	1
Open Findings	3
Readiness	27%
Assessment Date	2026-09-10

Readiness Area	Ready	Partial	Not Ready	Main Issue
Access Control		1	2	0 MFA exceptions and review evidence
Security Operations		2	3	1 IR tabletop and vulnerability evidence
Availability		1	1	0 Restore evidence
Vendor / Cloud		0	2	0 Critical vendor and cloud exception review
Governance / Evidence		2	7	0 Evidence ownership and policy cadence
				22 controls; matches overall: Yes
TOTAL		6	15	1

Control ID	Control Name	TSC Area	Trust Service Category	Owner	Frequency	Readiness Status	Evidence Needed	Evidence Review Priority	Readiness Area
AC-01	MFA Enforcement	CC6	Security	VP of IT	Continuous	Partial	MFA configuration and enrollment report	High	Access Control
AC-02	Access Reviews	CC6	Security	GRC Lead	Quarterly	Partial	Q access review evidence	Medium	Access Control
AC-03	Terminated User Removal	CC6	Security	People Ops	Per termination	Ready	Termination ticket and deactivation log	Medium	Access Control
VM-01	Vulnerability Scanning	CC7	Security	Security Engineer	Monthly	Partial	Monthly scan report	Medium	Security Operations
VM-02	Critical Vulnerability SLA	CC7	Security	Security Engineer	Monthly	Partial	Aging report and exceptions	Medium	Security Operations
LOG-01	Security Logging	CC7	Security	Security Ops	Continuous	Partial	Log source inventory	Medium	Security Operations
IR-01	Incident Response Plan	CC7	Security	CISO	Annual	Ready	Approved IR plan	Medium	Security Operations
IR-02	Incident Tabletop	CC7	Security	CISO	Annual	Not Ready	Tabletop evidence	Medium	Security Operations
BC-01	Backup Monitoring	A1	Availability	Infrastructure	Daily	Ready	Backup logs	Medium	Availability
BC-02	Restore Testing	A1	Availability	Infrastructure	Annual	Partial	Restore test record	Medium	Availability
TPRM-01	Critical Vendor Review	CC9	Security	GRC Lead	Annual	Partial	Vendor review evidence	High	Vendor / Cloud
CHG-01	Production Change Approval	CC8	Security	Engineering	Per change	Ready	Pull request approvals	Medium	Security Operations
SEC-01	Security Awareness Training	CC2	Security	People Ops	Annual	Partial	Training completion report	Low	Governance / Evidence
POL-01	Security Policy Review	CC1	Security	GRC Lead	Annual	Partial	Approved policies	Medium	Governance / Evidence
DATA-01	Data Retention	C1	Confidentiality	Legal	Annual	Partial	Retention matrix	Medium	Governance / Evidence
CLD-01	Cloud Configuration Monitoring	CC7	Security	Cloud Engineering	Monthly	Partial	Configuration report	High	Vendor / Cloud
HR-01	Background Checks	CC1	Security	People Ops	Per hire	Ready	Background screening evidence	Low	Governance / Evidence
PRIV-01	Privacy Commitments	P1	Privacy	Legal	Annual	Partial	Privacy notice and DPA	Medium	Governance / Evidence
EVD-01	Evidence Ownership	CC3	Security	GRC Lead	Monthly	Partial	Evidence owner matrix	Medium	Governance / Evidence
RISK-01	Risk Register Review	CC3	Security	CISO	Quarterly	Ready	Risk register review record	Medium	Governance / Evidence
TRUST-01	Customer Assurance Responses	CC2	Security	GRC Lead	As needed	Partial	Questionnaire response archive	Low	Governance / Evidence
MON-01	Security Metrics Reporting	CC4	Security	CISO	Quarterly	Partial	Security metrics dashboard	Medium	Governance / Evidence

Request ID	Control ID	Evidence Requested	Owner	Due Date	Status	Auditor-Style Comment	Priority
PBC-001	AC-01	MFA configuration export	VP of IT	2026-09-15	Received	Covers employees; contractor exceptions need follow-up	High
PBC-002	AC-02	Q2 access review evidence	GRC Lead	2026-09-20	Partial	Missing approval timestamp	Medium
PBC-003	VM-01	Monthly vulnerability scan reports	Security Engineer	2026-09-25	Received	Need aging summary	Medium
PBC-004	IR-02	Incident tabletop evidence	CISO	2026-10-15	Missing	No current-year exercise	Medium
PBC-005	BC-02	Backup restoration test	Infrastructure	2026-10-31	Partial	Restore test scheduled	Medium
PBC-006	TPRM-01	Critical vendor review evidence	GRC Lead	2026-09-30	Partial	DataFlow findings open	High
PBC-007	CHG-01	Production change sample	Engineering	2026-09-25	Received	No exception noted	Medium
PBC-008	SEC-01	Training completion report	People Ops	2026-10-01	Partial	Contractor report missing	Low
PBC-009	POL-01	Approved policy set	GRC Lead	2026-09-15	Received	Review calendar needed	Medium
PBC-010	CLD-01	Cloud configuration monitoring report	Cloud Engineering	2026-10-10	Partial	Exceptions not formally reviewed	High

Finding ID	Control ID	Finding	Severity	Root Cause	Corrective Action	Owner	Target Date	Status
SOCF-001	AC-01	Contractor MFA evidence incomplete	High	Contractor identity process outside normal evidence review	Require contractor MFA report and update onboarding	VP of IT	2026-09-30	Open
SOCF-002	AC-02	Access review approval evidence incomplete	Medium	Manual review evidence lacks timestamp	Adopt dated approval workflow	GRC Lead	2026-10-15	Open
SOCF-003	IR-02	No current-year tabletop evidence	Medium	Exercise not completed before readiness review	Conduct tabletop and retain lessons learned	CISO	2026-11-15	Planned
SOCF-004	VM-02	Critical vulnerability SLA exceptions not formally approved	Medium	Exception process not consistently documented	Require risk acceptance for overdue criticals	Security Engineer	2026-10-31	Open
SOCF-005	EVD-01	Evidence ownership decentralized	Medium	Evidence retained across multiple team folders	Create evidence owner matrix and central tracker	GRC Lead	2026-09-30	In Progress

Finding ID	Action	Owner	Target Date	Status	Validation Method	Executive Escalation	Interview Point
SOCF-001	Require contractor MFA report and update onboarding	VP of IT	2026-09-30	Open	Inspect updated evidence and confirm exception closure	Escalate if not closed before audit period	A finding is only closed when evidence proves remediation.
SOCF-002	Adopt dated approval workflow	GRC Lead	2026-10-15	Open	Inspect updated evidence and confirm exception closure	Track in readiness sprint	A finding is only closed when evidence proves remediation.
SOCF-003	Conduct tabletop and retain lessons learned	CISO	2026-11-15	Planned	Inspect updated evidence and confirm exception closure	Track in readiness sprint	A finding is only closed when evidence proves remediation.
SOCF-004	Require risk acceptance for overdue criticals	Security Engineer	2026-10-31	Open	Inspect updated evidence and confirm exception closure	Track in readiness sprint	A finding is only closed when evidence proves remediation.
SOCF-005	Create evidence owner matrix and central tracker	GRC Lead	2026-09-30	In Progress	Inspect updated evidence and confirm exception closure	Track in readiness sprint	A finding is only closed when evidence proves remediation.

Readiness Summary

Overall Status	Partially Ready	Executive Message	Do not begin audit period until high-priority evidence gaps close.
Top Blocker	Contractor MFA evidence	Severity	High
60-90 Day Sprint	Close access, IR, vulnerability, backup, and evidence ownership gaps.	Owner	CISO / GRC
Strong Candidate Talking Point	SOC 2 readiness is about proving controls operated, not collecting random screenshots.	Why It Stands Out	Shows audit evidence maturity
Next Step	Complete remediation tracker and conduct internal readiness retest.	Target	2026-11-30
Customer Value	Improves security questionnaire responses and future audit readiness.	Portfolio Use	Capstone project
Audit Risk	Missing or incomplete evidence may delay audit or create exceptions.	Decision	Readiness sprint required
Assessment Date	2026-09-10	Primary Criteria	AICPA Trust Services Criteria

Reference	URL	Use
NIST CSF 2.0	https://www.nist.gov/cyberframework	Program outcomes and governance alignment
NIST SP 800-53 Rev. 5 Release 5.2.0	https://csrc.nist.gov/News/2025/nist-releases-revision-to-sp-800-53-controls	Control catalog reference
NIST SP 800-53A Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/a/r5/final	Control assessment and test procedure reference
CIS Controls v8.1	https://www.cisecurity.org/controls/v8-1	Practical safeguard mapping
ISO/IEC 27001:2022/Amd 1:2024	https://www.iso.org/standard/88435.html	ISMS requirements
ISO/IEC 27002:2022	https://www.iso.org/standard/75652.html	Security control guidance
ISO/IEC 27017:2026	https://www.iso.org/standard/43757.html	Cloud-service control guidance
AICPA Trust Services Criteria with revised points of focus 2022	https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022	SOC 2 readiness criteria
NIST SP 800-61 Rev. 3	https://csrc.nist.gov/pubs/sp/800/61/r3/final	Incident-response control guidance
NIST SP 800-161 Rev. 1 Update 1	https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final	Supply-chain controls
Scenario dates and rating definitions	Fictional assessment assumptions; see shared company profile	../00-company-profile/Northbridge-Company-and-GRC-Scope.md